

SIMATS ENGINEERING
ASSESSMENT TOOL 2

COURSE CODE: CSA5115

COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO4: *Implement best security practices for IP, email, and web service using PGP, S/MIME for enhancing email Security.CO (BL3, BL6)*

Assessment Tool Weightage: 20%

QUESTIONS: 5

TOTAL MARKS: 25

Annexure A

Industry Problem-Solving Task

Code of Conduct:

I D. Gnana Deepthi(192411123) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:



D. Gnana Deepthi.

Annexure A

Industry Problem-Solving Task

1. A multinational enterprise is deploying IPSec to secure communication between its branch offices over the public internet. Analyze how Authentication Header (AH) and Encapsulating Security Payload (ESP) should be configured to ensure both integrity and confidentiality across different types of traffic.

Tasks:

- A. Identify which traffic requires AH, ESP, or both
 - B. Design packet flow with appropriate IPSec modes (transport/tunnel)
 - C. Justify protocol selection for different data types
 - D. Evaluate performance vs security trade-offs
-
2. An organization faces frequent key management issues in its IPSec implementation, leading to expired or mismatched keys. Propose a solution to efficiently manage Security Associations (SA) and automate key exchange in a scalable enterprise environment.

Tasks:

- A. Analyze current SA lifecycle issues
- B. Design an automated key management mechanism (e.g., IKE-based)
- C. Propose a strategy for key renewal and revocation
- D. Evaluate scalability and fault tolerance

3. A financial services company needs to implement secure email communication for sensitive transactions. Evaluate and recommend between Pretty Good Privacy (PGP) and S/MIME based on usability, scalability, and enterprise integration requirements.

Tasks:

- A. Compare PGP and S/MIME in real-world deployment scenarios
- B. Analyze key management and trust models
- C. Recommend a solution with justification
- D. Design a high-level implementation workflow

4. A company's email system is experiencing a rise in phishing and spam attacks despite basic filtering mechanisms. Analyze the weaknesses in the current system and propose an advanced spam detection strategy using email headers and content analysis.

Tasks:

- A. Identify limitations of existing filtering techniques
- B. Analyze email headers for spoofing indicators
- C. Design an improved detection model (rule-based or ML-based)
- D. Evaluate effectiveness and false positive handling

5. During a security audit, it is found that encrypted email messages are vulnerable due to improper certificate handling in S/MIME. Diagnose the possible issues and recommend best practices to ensure secure certificate management and trust validation.

Tasks:

- A. Identify potential certificate-related vulnerabilities
- B. Analyze trust chain and validation process
- C. Propose secure certificate storage and management practices
- D. Recommend improvements for user awareness and system configuration

ANSWERS

1. Secure Email Communication: PGP vs S/MIME

A. Comparison of PGP and S/MIME in Real-World Deployment

Feature	PGP	S/MIME
Usability	May require users to manage keys and verify identities manually	Generally easier for users in enterprise email clients

Feature	PGP	S/MIME
Trust Model	Web of Trust	Centralized Certificate Authority (CA) model
Key Management	Users generate and exchange their own public keys	Digital certificates are issued and managed by a CA
Scalability	More suitable for individuals and small groups	Highly suitable for large organizations
Enterprise Integration	May require additional configuration	Integrates well with enterprise email systems
Administration	More decentralized	Centrally managed
Best Use Case	Personal and community-based secure communication	Corporate and financial organizations

PGP is flexible and provides strong encryption, but managing and verifying keys can become difficult when the number of employees increases. **S/MIME** is more suitable for organizations because certificates and policies can be centrally managed.

B. Key Management and Trust Models

PGP – Web of Trust

PGP uses a decentralized Web of Trust model. Users generate their own public and private key pairs. Other users verify identities and sign public keys to indicate trust.

Advantages:

- No dependence on a central authority.
- Flexible and user-controlled.

Disadvantages:

- Difficult to manage for thousands of employees.
- Users must understand key verification and trust relationships.
- Revocation and key recovery can be more complex.

S/MIME – Certificate Authority Model

S/MIME uses X.509 digital certificates issued by a trusted Certificate Authority or an organization's internal PKI.

Advantages:

- Centralized certificate management.
- Easier user provisioning and revocation.
- Suitable for large enterprises.
- Supports organizational security policies.

Disadvantages:

- Requires PKI and certificate infrastructure.
- Dependence on trusted CAs.

C. Recommendation

S/MIME is recommended for the financial services company.

Justification:

1. **Better enterprise integration:** S/MIME works effectively with many corporate email systems and enterprise security infrastructures.
2. **Centralized key management:** Administrators can issue, renew, revoke, and manage employee certificates centrally.
3. **High scalability:** It is easier to manage secure email communication for a large number of employees.
4. **Improved usability:** Employees can use encryption and digital signatures with minimal technical knowledge.
5. **Compliance support:** Centralized certificate management and auditing are useful for financial organizations handling sensitive transactions.

Therefore, **S/MIME provides a more scalable, manageable, and enterprise-friendly solution than PGP** for this scenario.

D. High-Level S/MIME Implementation Workflow

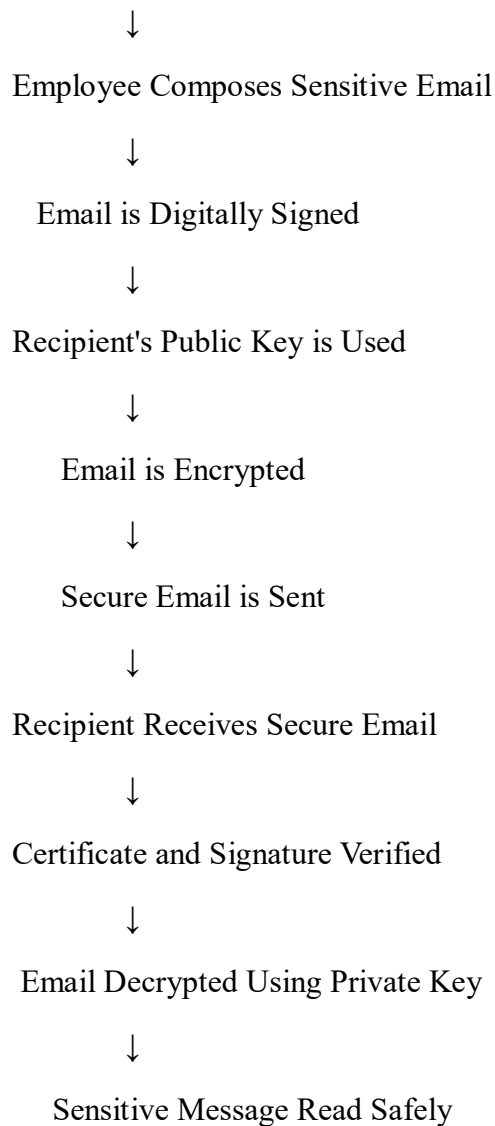
Employee → Requests Digital Certificate



Certificate Authority (CA)



Issues X.509 Certificate



Implementation Steps

1. Set up a PKI or trusted Certificate Authority.
2. Generate and issue digital certificates for all employees.
3. Integrate S/MIME with the company's email server and email clients.
4. Publish and exchange public certificates through a secure directory.
5. Digitally sign sensitive emails to ensure authenticity and integrity.
6. Encrypt sensitive emails using the recipient's public key.
7. Decrypt received emails using the recipient's private key.
8. Verify digital signatures and certificates before accepting messages.
9. Implement certificate renewal and revocation procedures.

10. Maintain audit logs and enforce security policies for regulatory compliance.

Conclusion

For a financial services company, both PGP and S/MIME provide confidentiality, integrity, authentication, and non-repudiation. However, S/MIME is the better choice because of its centralized trust model, easier key management, scalability, and strong integration with enterprise email systems.

4. Advanced Spam and Phishing Detection Using Email Headers and Content Analysis

A. Limitations of Existing Filtering Techniques

Basic spam filters often use simple techniques such as keyword matching, blacklists, and sender blocking. These methods have several limitations:

- Keyword-based filtering: Attackers can change spellings or use images to bypass filters.
- Blacklists: New phishing domains and email addresses may not yet be listed.
- Static rules: Fixed rules cannot easily detect new attack patterns.
- Header checking limitations: Basic systems may not properly validate sender authentication.
- False positives: Legitimate emails may be incorrectly marked as spam.
- No content context analysis: Basic filters may fail to identify suspicious language or social engineering techniques.

B. Email Header Analysis for Spoofing Indicators

The system should analyze important email headers to detect spoofing and suspicious messages.

Header/Feature Spoofing Indicator

From	Displayed sender domain differs from the actual sending domain
Return-Path	Different from the claimed sender address

Header/Feature Spoofing Indicator

Reply-To	Points to an unrelated or suspicious domain
Received	Unusual server path or suspicious originating IP address
SPF	SPF validation fails
DKIM	Digital signature verification fails
DMARC	Sender domain policy validation fails
Message-ID	Domain does not match the sender's domain

For example, if an email claims to be from bank.com but the Return-Path or Reply-To contains another suspicious domain, the email may be a phishing attempt.

C. Improved Spam Detection Model

A hybrid detection model combining rule-based filtering and machine learning can provide better protection.

Step 1: Header Analysis

Extract features such as:

- SPF, DKIM, and DMARC results
- From and Reply-To domain mismatch
- Suspicious IP addresses
- Number of email hops
- Message-ID domain mismatch

Step 2: Content Analysis

Analyze the subject and body for:

- Suspicious words such as *urgent*, *verify account*, or *click immediately*
- Fake login requests
- Suspicious URLs
- URL domain mismatches
- Excessive links
- Attachments with dangerous extensions

- Unusual spelling and grammar patterns

Step 3: ML-Based Classification

The extracted features can be given to a machine learning classifier.

Incoming Email



Header Analysis + Content Analysis



Feature Extraction



Rule-Based Security Checks



Machine Learning Classifier



Risk Score Calculation



Low Risk	Medium Risk	High Risk	
Deliver	Quarantine	Block / Alert	

A model such as Naive Bayes, Random Forest, or Logistic Regression can classify emails as legitimate, spam, or phishing.

D. Effectiveness and False Positive Handling

The effectiveness of the detection system can be evaluated using:

- Accuracy: Percentage of correctly classified emails.
- Precision: Percentage of detected spam that is actually spam.
- Recall: Ability to detect all spam and phishing emails.
- False Positive Rate: Legitimate emails incorrectly classified as spam.
- False Negative Rate: Malicious emails incorrectly allowed into the inbox.

To reduce false positives:

1. Use a risk score instead of immediately blocking every suspicious email.
2. Send medium-risk emails to a quarantine folder.
3. Allow users to mark emails as “Not Spam”.
4. Use user feedback to improve the ML model.
5. Maintain a trusted sender allowlist.
6. Periodically update rules and retrain the model using new phishing examples.

Conclusion

Basic filtering alone is not sufficient against modern phishing and spam attacks. A hybrid approach using email header authentication, content analysis, rule-based checks, and machine learning provides stronger detection. The use of risk scoring and quarantine mechanisms helps improve security while reducing false positives.

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem context
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis
Professionalism	5%	Highly professional, well-	Good documentatio	Basic documentati	Poor documentati

		documented, and clearly presented work	n and presentation	on with some gaps	on and presentation
--	--	---	-----------------------	----------------------	------------------------